Room Name: Content Discovery

Objective: To understand how to discover hidden files, directories, subdomains, and other resources on a web server using manual techniques, OSINT, and automated enumeration.

Key Concepts Learned:

- Content Discovery and Attack Surface Mapping
- Manual, Automated, and OSINT-based Discovery
- robots.txt and sitemap.xml
- Favicon Fingerprinting
- HTTP Response Headers
- Web Framework Identification
- Google Hacking / Dorking
- Technology Stack Identification
- Website History and Archived Content
- GitHub Repository and Commit History Analysis
- Amazon S3 Bucket Enumeration
- Directory and File Enumeration
- Wordlists and Brute-Force Discovery
- DNS Subdomain Enumeration
- Virtual Host (VHost) Enumeration
- Subdomains vs. Virtual Hosts

Tools and Websites Covered:

- **Firefox Browser:** Used to manually explore websites, inspect common files, and access discovered directories and endpoints.
- **cURL:** Used to send HTTP requests and inspect response headers, server information, and page source.
- **Google Search (Dorking):** Used to find indexed pages, exposed files, login portals, and other publicly available information through advanced search operators.
- **Wappalyzer:** Used to identify website technologies, frameworks, CMS platforms, and other components of the technology stack.
- **Wayback Machine:** Used to explore archived versions of websites and discover previously available pages, login forms, and API endpoints.
- **GitHub:** Used to search public repositories, inspect project files, and review commit history for accidentally exposed sensitive information.
- **Amazon S3:** Explored cloud storage buckets and their URL structures to understand how publicly accessible storage can expose files.
- **Gobuster:** Used for automated directory/file, DNS subdomain, and virtual host enumeration.
- **SecLists:** Used as a collection of wordlists for directory and subdomain discovery.
- **DNSmasq:** Used to configure DNS resolution for the room's lab environment.
- **Nano:** Used to edit DNS resolver and hosts configuration files.

Practical Work:

- Inspected `robots.txt` and `sitemap.xml` to identify hidden directories, restricted paths, and additional application endpoints.
- Examined HTTP response headers and page source to identify server information, custom headers, framework details, and hidden references.
- Explored framework documentation to understand its directory structure and locate its administration portal.
- Practiced Google Dorking using operators such as `site`, `inurl`, `filetype`, `intitle`, and `intext`.
- Explored Wappalyzer to identify technologies used by websites.
- Used the Wayback Machine to understand how archived website versions can reveal removed content.
- Explored GitHub repositories and commit history to understand how sensitive information can remain exposed.
- Learned common Amazon S3 bucket naming patterns and how publicly accessible storage can expose files.
- Used Gobuster with SecLists wordlists to discover directories and files.
- Configured DNS resolution through `/etc/resolv-dnsmasq` and updated `/etc/hosts` for the lab environment.
- Practiced Gobuster DNS mode to discover subdomains.
- Used Gobuster VHost mode to identify virtual hosts through HTTP Host header testing.

Useful Commands:

```
# Inspect HTTP headers and page source
curl http://MACHINE_IP -v

# Access common discovery files in a browser
http://MACHINE_IP/robots.txt
http://MACHINE_IP/sitemap.xml

# Check Gobuster options
gobuster --help

# Directory and file enumeration
gobuster dir -u http://MACHINE_IP -w
/usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt

# Search for specific file extensions
gobuster dir -u http://MACHINE_IP -w
/usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt -x
.php,.txt,.js

# Configure DNS resolver for the lab
sudo nano /etc/resolv-dnsmasq

# Restart DNSmasq
/etc/init.d/dnsmasq restart

# Update the local hosts file
sudo nano /etc/hosts

# Verify domain resolution
ping example.thm

# Subdomain enumeration using Gobuster
```

```
gobuster dns -d example.thm -w
/usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
--wildcard

# Virtual host enumeration
gobuster vhost -u http://MACHINE_IP --domain example.thm -w
/usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
--append-domain --exclude-length 250-320
```

Important Observations:

- Content discovery helps identify resources that are not directly linked or easily visible on a website.
- `robots.txt` provides crawling instructions, while `sitemap.xml` lists URLs that can reveal additional application paths. Neither file provides access control.
- HTTP headers such as `Server`, `X-Powered-By`, and custom headers can expose useful server and framework information.
- Page source code and favicon information can help identify the technologies and frameworks used by a website.
- Google Dorking, Wappalyzer, Wayback Machine, and GitHub provide different ways to collect publicly available information.
- Exposed GitHub repositories and misconfigured S3 buckets can reveal sensitive files, credentials, and configuration details.
- Gobuster `dir` mode discovers directories and files, `dns` mode discovers subdomains, and `vhost` mode identifies virtual hosts.
- Subdomains are resolved through DNS, whereas virtual hosts are identified through the HTTP Host header.
- Wordlists directly affect enumeration results, and response status codes and lengths help identify interesting results and filter false positives.
- Content discovery findings help map the application's attack surface and identify potential areas for further security testing.

Room Link: https://tryhackme.com/room/contentdiscoveryx

Status: Complete